DBMS 보안 점검 가이드

Object 권한 관리, GRANT OPTION 제한, 자원 제한 설정, xp_cmdshell 사용 제한, Registry Procedure 권한 제한 등 DBMS 옵션 관리 핵심 보안 점검 항목을 다룹니다.

DBMS 보안 | 옵션 관리

OBJECT 권한 관리

Altibase — Object 권한 확인 및 회수

Step 1) 권한 정보 조회

```
SELECT * FROM system._sys_grant_object;
SELECT * FROM system._sys_privileges;
```

Step 2) 불필요한 권한 회수

```
REVOKE <권한> ON <Object>
FROM [소유자];
```

부여된 권한 ID를 확인한 후, 불필요한 Object 권한을 회수합니다. 모든 사용자는 자동으로 해당 테이블에 대한 SELECT 권한을 가집니다.

Priv ID	Object Privilege	Table	Sequence	PSM/Ext Proc	View	Dir
101	ALTER	○	○			
102	DELETE	○				
103	EXECUTE			○		○
107	SELECT	○	○		○	
108	UPDATE	○				

OBJECT 권한 관리

Tibero / PostgreSQL — Object 권한 점검

Tibero

Step 1) 모든 스키마 Object 특권 조회

```
SELECT * FROM dba_tbl_privs;
```

Step 2) 인가받지 않은 Object 권한 소유자 발견 시 권한 회수

PostgreSQL

Step 1) Object 권한 정보 확인

```
SELECT DISTINCT relowner FROM pg_class
WHERE relowner NOT IN
(SELECT usesysid FROM pg_user
WHERE usesuper = TRUE);
```

Step 2) 잘못된 Object 권한 소유자 발견 시 권한 회수

D-21 중 | 옵션 관리

인가되지 않은 GRANT OPTION 사용 제한

점검 목적

GRANT OPTION을 ROLE에 의해 설정하여 권한 남용을 방지하고 안정성을 확보합니다.

보안 위험

일반 사용자에게 GRANT OPTION이 부여되면, 해당 사용자가 Object 소유자처럼 다른 사용자에게 권한을 부여할 수 있어 중요 정보 유출 위험이 존재합니다.

판단 기준

✅ 양호

WITH_GRANT_OPTION이 ROLE에 의하여 설정된 경우

❌ 취약

WITH_GRANT_OPTION이 ROLE에 의하여 설정되지 않은 경우

대상: Oracle DB, MySQL, Altibase, Tibero

D-21 점검 조치

GRANT OPTION 점검 및 조치 사례

Oracle DB / Tibero

```
SELECT grantee || ':' || owner || ':'
|| table_name
FROM dba_tab_privs WHERE
grantable = 'YES'
AND owner NOT IN
('SYS','SYSTEM','WMSYS',...)
AND grantee NOT IN (SELECT
grantee FROM dba_role_privs
WHERE granted_role = 'DBA')
ORDER BY grantee;
```

계정이 나오는 경우 취약 → **REVOKE role FROM user;**

MySQL

```
SELECT user, grant_priv FROM
mysql.user;
```

계정이 나오는 경우 취약 → **REVOKE <권한> ON <대상> FROM [계정명];**

Altibase

```
SELECT * FROM system._sys_users;
SELECT * FROM
system._sys_grant_object;
SELECT * FROM
system._sys_privileges;
```

with grant option이 1로 부여된 경우 취약 → **REVOKE <권한> ON FROM [계정명];**

D-22 하

옵션 관리

데이터베이스 자원 제한 기능 TRUE 설정

개요

RESOURCE_LIMIT 값을 TRUE로 설정하여 자원의 과도한 사용을 방지하고, 데이터베이스의 안정성과 효율적인 자원 관리를 보장합니다.

보안 위협

FALSE로 설정 시 특정 사용자가 과도한 자원을 소비하여 시스템 과부하 위험이 존재합니다.

대상: **Oracle DB**

조치 방법 (Oracle DB)

Step 1) init.ora 설정 파일에 추가

```
#vi /Oracle_HomeDirectory/admin/
    pfile/init.ora
→ RESOURCE_LIMIT = TRUE 추가
```

Step 2) SQL*Plus에서 설정 및 확인

```
ALTER SYSTEM SET RESOURCE_LIMIT = TRUE;
SHOW PARAMETER RESOURCE_LIMIT;
```

양호: RESOURCE_LIMIT = TRUE / 취약: RESOURCE_LIMIT = FALSE

D-23 상 | 옵션 관리

xp_cmdshell 사용 제한

점검 목적 및 보안 위험

불필요하게 활성화된 xp_cmdshell을 제한하여 공격자의 무단 접근 및 악성코드 실행 위험을 감소시킵니다. 해킹 툴에서 자주 이용되며 권한 상승, 데이터 유출 위험이 존재합니다.

판단 기준 (MSSQL)

- 양호: xp_cmdshell 비활성화, 또는 활성화 시 public 실행 권한 미부여 + 서비스 계정에 sysadmin 미부여
- 취약: xp_cmdshell 활성화 + 양호 조건 미충족

쿼리로 활성화 여부 확인

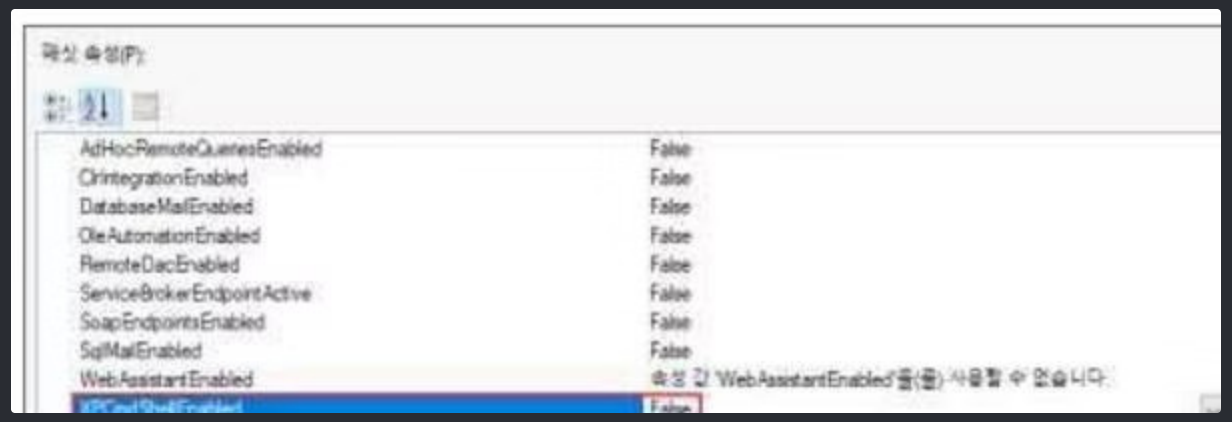
```
SELECT name, value FROM sys.configurations
WHERE name = 'xp_cmdshell';
-- value=1: 활성화, value=0: 비활성화
```

비활성화 설정 (쿼리)

```
EXEC sp_configure 'show advanced options',1;
GO RECONFIGURE; GO
EXEC sp_configure 'xp_cmdshell', 0; GO
RECONFIGURE; GO
```

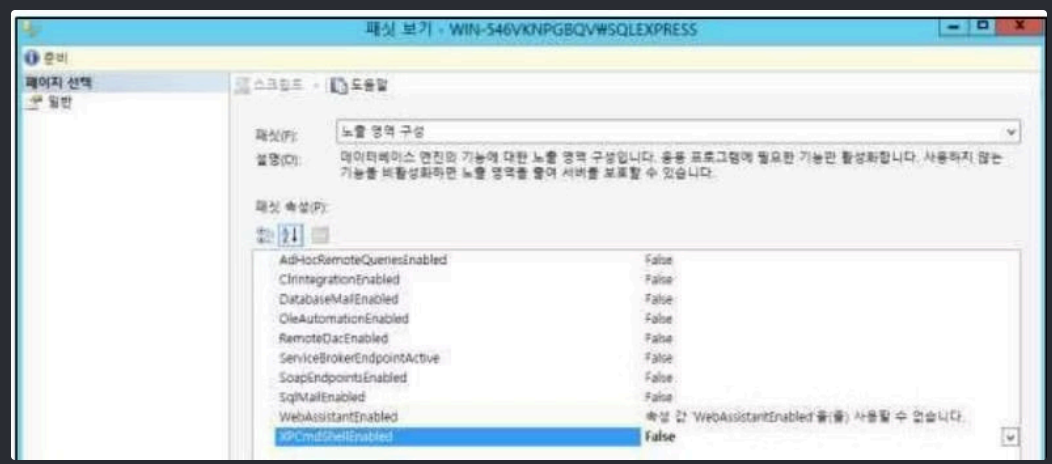
D-23 조치 사례

xp_cmdshell — GUI 설정 및 권한 제거



xp_cmdshell 비활성화 확인

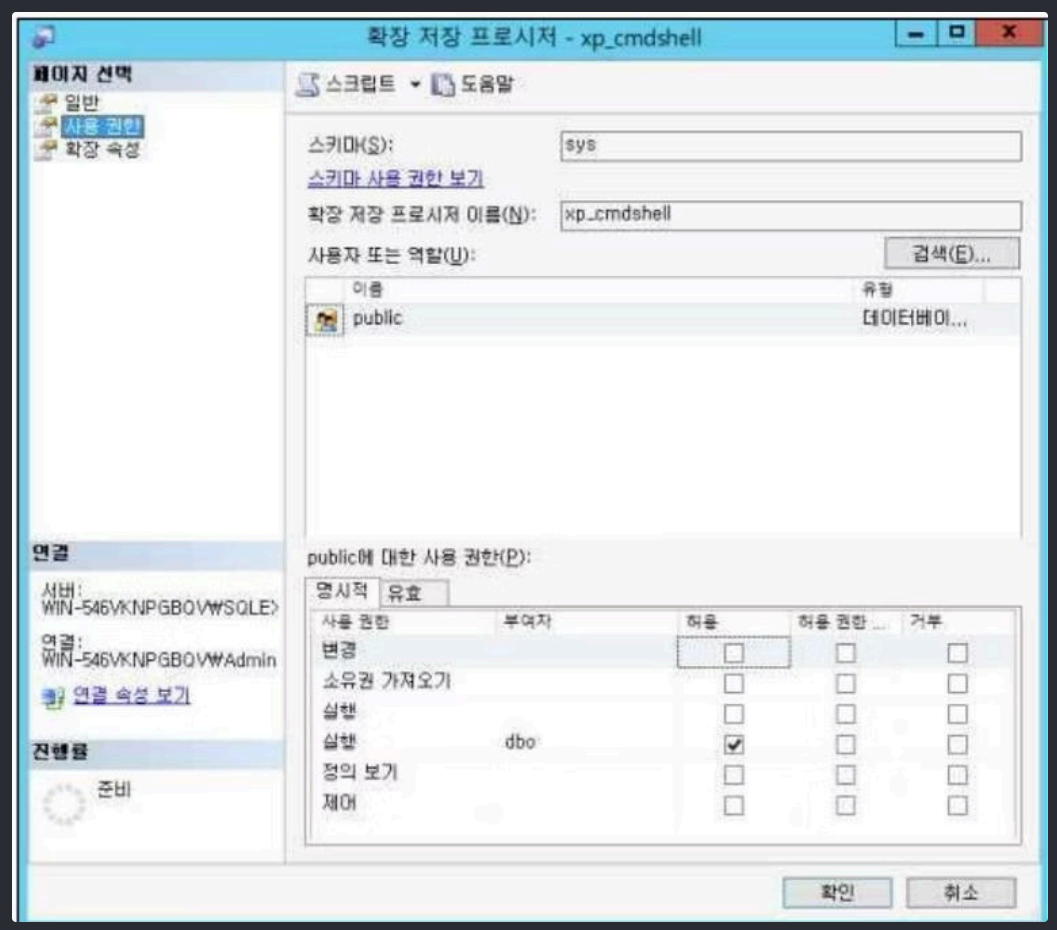
SQL Server Management Studio → 개체 탐색기 → 컴퓨터 이름 우클릭 → 패스 → 일반에서 **XPCmdShellEnabled = False** 확인

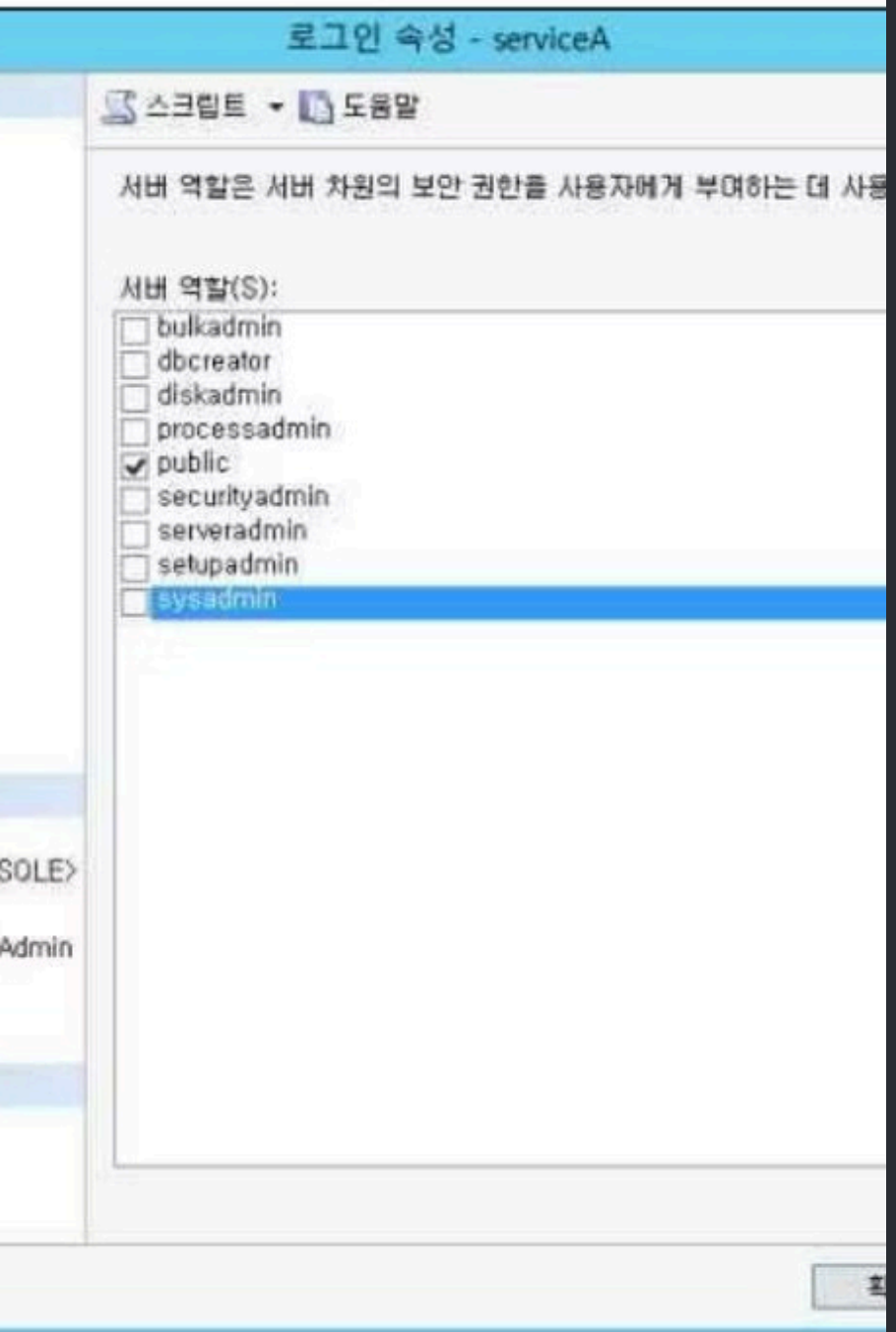


사용이 필요한 경우 — public 실행 권한 제거

master → 프로그래밍 기능 → 확장 저장 프로시저 → xp_cmdshell → 속성 → 사용권한에서 public 실행 권한 제거

```
REVOKE EXECUTE ON
master.dbo.xp_cmdshell TO public
```





D-23 SYSADMIN 제거

서비스 계정 sysadmin 권한 제거

sysadmin 권한 계정 확인

```
EXEC sp_helpsrvrolemember
'sysadmin'
```

serviceA 등 불필요한 서비스 계정이 sysadmin으로 등록된 경우 취약합니다.

sysadmin 권한 제거

GUI: 개체탐색기 → 보안 → 로그인 → 계정 선택 → 속성 → 서버 역할에서 sysadmin 제거

```
EXEC
master..sp_dropsrvrolemember
@loginame = N'<계정명>',
@rolename = N'sysadmin'
```

⚠ 조치 시 xp_cmdshell을 이용한 OS 명령 실행 서비스가 동작하지 않을 수 있습니다.

D-24 상 | 옵션 관리

Registry Procedure 권한 제한 (MSSQL)

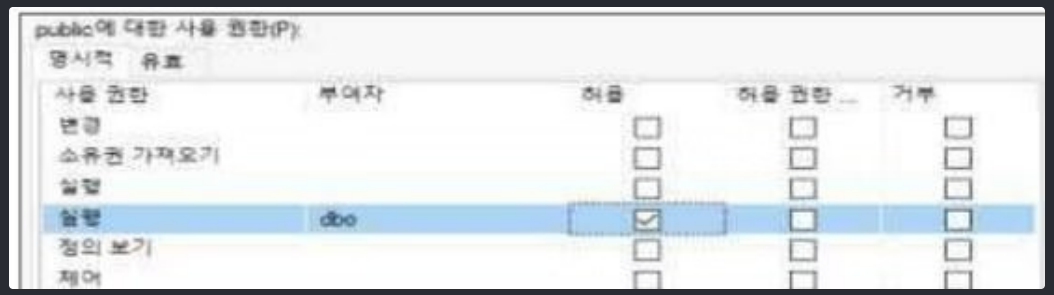
보안 위협 및 판단 기준

불필요한 레지스트리 접근 권한 미제한 시 공격자가 시스템 변경, 악성 소프트웨어 설치를 통해 권한 상승·데이터 유출·시스템 장애를 유발할 수 있습니다.

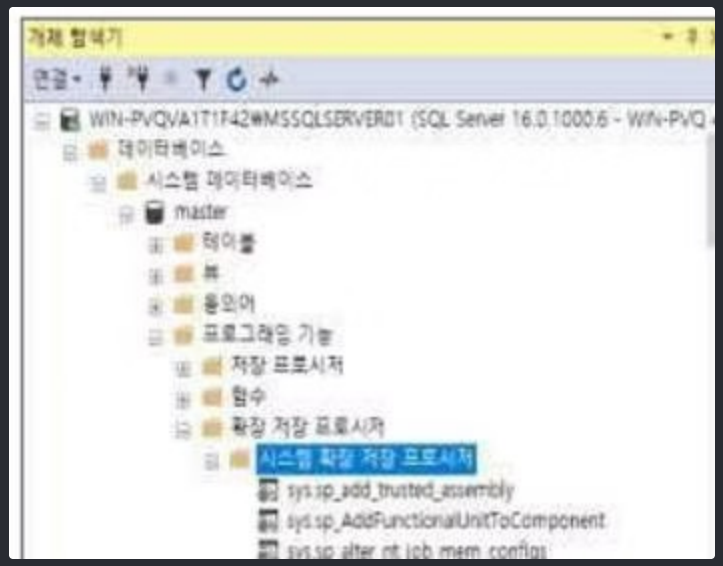
양호: 시스템 확장 저장 프로시저가 DBA 외 guest/public에게 미부여
취약: guest/public에게 부여된 경우

조치 방법

각 프로시저 → 속성 → 사용 권한 → public 실행 권한 제거(체크 해제)



제한 대상 시스템 확장 저장 프로시저



- sys.xp_readmultistring
- sys.xp_regdeletekey
- sys.xp_regdeletevalue
- sys.xp_regenumvalues
- sys.xp_regread
- sys.xp_regwrite